Northgate Example Clinic: Information Security Policy

A fictional policy written for testing. Northgate Example Clinic is not a real organisation and this document contains no real data. It covers some HIPAA Security Rule topics fully, some in part, and leaves others out on purpose.

Item	Detail
Document	Information Security Policy
Version	2.3
Owner	Chief Information Security Officer
Approved by	Executive Committee
Approved on	14 March 2026
Next scheduled review	March 2027

1. Purpose and scope

This policy sets out how Northgate Example Clinic ("the Clinic") protects electronic protected health information (ePHI) and keeps the systems that hold it available to the people who care for patients.

It applies to every employee, contractor, student and volunteer who creates, receives, maintains or transmits ePHI on the Clinic's behalf ("workforce members"). It covers all systems, applications, devices, networks and media that hold or carry ePHI, whether they are in the Clinic's buildings, at a vendor or in a cloud service.

2. Roles and responsibilities

The Chief Information Security Officer (CISO) is the designated security official for the Clinic. The CISO is responsible for developing, implementing and maintaining the policies and procedures in this document. The CISO has the authority to require changes to any system or practice that puts ePHI at risk, and reports to the Executive Committee each quarter.

System owners apply this policy to the systems they manage. Managers make sure that the people they supervise complete training and follow this policy.

3. Risk management

3.1 Risk analysis

The CISO leads a documented risk analysis that covers every system, location and medium that holds or transmits ePHI, including cloud services and portable devices. It identifies the threats and

vulnerabilities that could affect the confidentiality, integrity or availability of ePHI, and rates each risk by likelihood and impact.

The risk analysis is repeated every year. It is also updated whenever a new system is introduced, a security incident occurs or a major change is made to the environment.

3.2 Risk treatment

Risks rated high are entered in the risk register with an owner, a planned control and a due date. The CISO reviews the register every quarter and reports overdue items to the Executive Committee.

4. Workforce security

4.1 Access to ePHI

Access to ePHI is granted only after the data owner approves a written request that states the person's role and the systems needed. Access is limited to the minimum necessary for the role. When a person changes role, their manager submits a new request, and access that is no longer needed is removed.

Role	Access to ePHI	Approved by
Clinician	Records of the patients in their care	Clinical lead
Billing staff	Billing and claims data	Finance manager
IT administrator	Systems and databases, clinical content only when needed to fix a fault	CISO
Volunteer	None	Not applicable

4.2 Leaving the Clinic

When a workforce member leaves or an engagement ends, their accounts are disabled on their last working day. All badges, keys and equipment are returned to the security desk before they leave.

4.3 Sanctions

Workforce members who violate this policy are subject to disciplinary action, up to and including termination of employment or contract.

5. Training and malware protection

All workforce members, including managers and executives, complete security awareness training within 30 days of starting and again every year. Human Resources records completion. The training covers how to recognise phishing, how to handle ePHI and how to report an incident.

All workstations and servers run endpoint protection software that updates itself automatically.

6. Access control

6.1 Unique user identification

Every user has a unique user ID. Shared or generic accounts are not permitted on any system that holds ePHI, so that every action can be traced to one person.

6.2 Passwords and sign-in

Passwords must be at least 12 characters long and must never be shared with anyone. Users sign in to systems that hold ePHI with their user ID and password.

6.3 Automatic logoff

Sessions on workstations and applications that access ePHI lock after 10 minutes of inactivity. The user must enter their password again to continue.

7. Physical safeguards

7.1 Buildings and rooms

Server rooms and records areas are kept locked, and only authorised staff with a badge can enter them. Visitors sign in at reception and are escorted at all times.

7.2 Workstations

Workstations that access ePHI must be placed so that screens cannot be seen by visitors. Users lock their screen whenever they step away.

7.3 Disposal

Hard drives and other media that held ePHI are securely destroyed before they are disposed of.

8. Technical safeguards

8.1 Encryption of stored data

Laptops, servers, databases and removable media that hold ePHI are encrypted with AES-256.

8.2 Encryption of data in transit

ePHI that is sent over any network outside the Clinic is encrypted using TLS 1.2 or higher, or the Clinic's VPN. Workforce members must not send ePHI by ordinary email or by text message. The approved methods are the patient portal, the secure email gateway and SFTP.

8.3 Audit logging and review

Systems that hold ePHI record logins, access to patient records and changes to patient records. Logs are sent to a central logging service, where system administrators cannot change them, and are kept for 12 months. The security team reviews the log reports each month and follows up on unusual activity.

9. Security incidents

Workforce members must report any suspected security incident to the security desk immediately, by phone or email. The CISO investigates every report and records the outcome in the incident log. Where the law requires it, affected patients and regulators are notified.

10. Backup and recovery

10.1 Backups

Systems that hold ePHI are backed up every night. Backups are encrypted and copied to a secondary site. A sample restore is tested every six months.

10.2 Disaster recovery

IT maintains a disaster recovery plan for the Clinic's main systems.

11. Vendors and business associates

A vendor that creates, receives, maintains or transmits ePHI for the Clinic must sign a business associate agreement before it is given any data. The agreement requires the vendor to protect ePHI with appropriate administrative, physical and technical safeguards, and to report any security incident or breach of unsecured protected health information to the Clinic without unreasonable delay.

12. Policy governance and records

12.1 Review and availability

The CISO reviews this policy every year, and the Executive Committee approves it. The current version is available to all workforce members on the Clinic's intranet.

12.2 Retention

Security policies, procedures and records of security activities, including risk analyses, training records and incident logs, are kept for six years from the date they were created or last in effect, whichever is later.

13. Exceptions

A request for an exception to this policy must be made in writing and approved by the CISO. The CISO reviews every approved exception every six months.